Université de Limoges

Administration et Sécurité Système et Réseaux

Introduction et Rappels

Emmanuel Conchon (emmanuel.conchon@unilim.fr)

Université de Limoges

Présentation de l'Unité d'Enseignement

- UE centrée sur les protocoles et les implémentations
  - Partie pratique importante
- 2 axes d'études : sécurité et performance
- Nombreux intervenants professionnels
  - Thales, EADS, Sopra, CONIX, BPCE, Airbus...

Modalité d'évaluation :

- Session 1 : Projet (33%), Partiel (33%), Examen Terminal (33%)
- Session 2 : Oral (100%)

La Triade CID

La sécurité informatique repose sur trois piliers :

- La **confidentialité** des données
- L'**intégrité** des données et des systèmes
- La **disponibilité** des données et des systèmes

On peut également leur associer :

- Authenticité/Authentification
- Traçabilité (Accounting en anglais)
- Non-répudiation des données



Université de Limoges

La sécurité informatique ?

A la base, la plupart des problèmes viennent de mauvaises conceptions ou de mauvaises implémentations

- Beaucoup de bugs dans les programmes déployés

> On peut se faire beaucoup d'argent en trouvant et/ou en exploitant ses vulnérabilités

Il existe des Marketplaces pour

- des exploits (CVE) (gain d'un avantage)
- des malwares (post compromise)

Université de Limoges

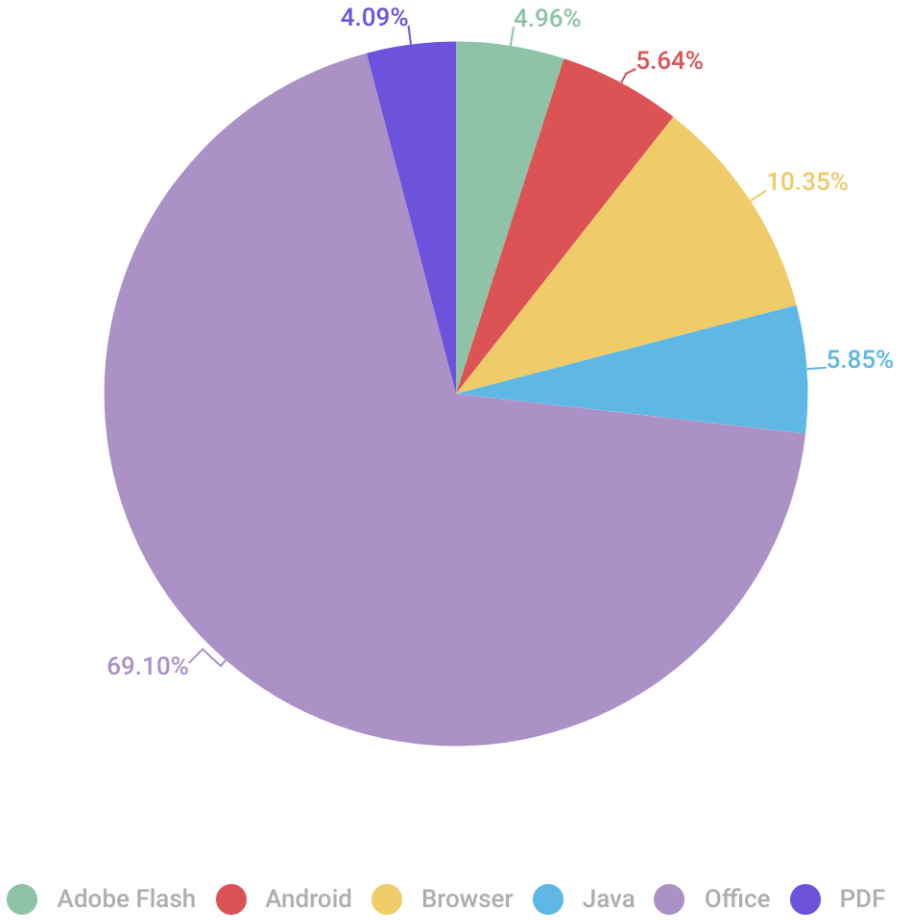
La sécurité informatique ?

Exemples de vulnérabilités recensées en 2025 (https://www.cvedetails.com/top-50-products.php?year=2025)

Nom du produit	Fabricant	# vulnerabilités
Linux Kernel	Linux	1542
Windows Server 2025	Microsoft	502
Windows 11 24H2	Microsoft	439
Macos	Apple	410
Windows 10 22h2	Microsoft	407
Iphone Os	Apple	210
Android	Google	130
Firefox	Mozilla	130
Chrome	Google	101

La sécurité informatique ?

Source : Kaspersky statistics 2023



Université de Limoges

Objectifs de l'UE

Dans cette UE, nous aborderons différents points :

- Bases de la sécurité informatique
  - Contrôle d'accès, test d'intrusion...
- Sécurité des réseaux
  - Protocoles et implémentation
- Sécurité des applications
  - Détection et exploitation de failles logicielles
  - Durcissement d'API web...

Université de Limoges

Administration et Sécurité Système et Réseaux

Sécurité des Réseaux : Rappels

Université de Limoges

Types d'attaques

Dans le cadre des réseaux informatiques les attaques vont cibler la pile réseau avec un corollaire

> Lorsqu'un attaquant prend le contrôle d'un niveau de la pile, il a le contrôle de tous les niveaux supérieurs

Les attaques vont se classer en **deux grandes catégories**

- **Passives** : Difficile à détecter mais simple à prévenir
- **Actives** : Simple à détecter mais difficile à prévenir

Université de Limoges

Les attaques passives

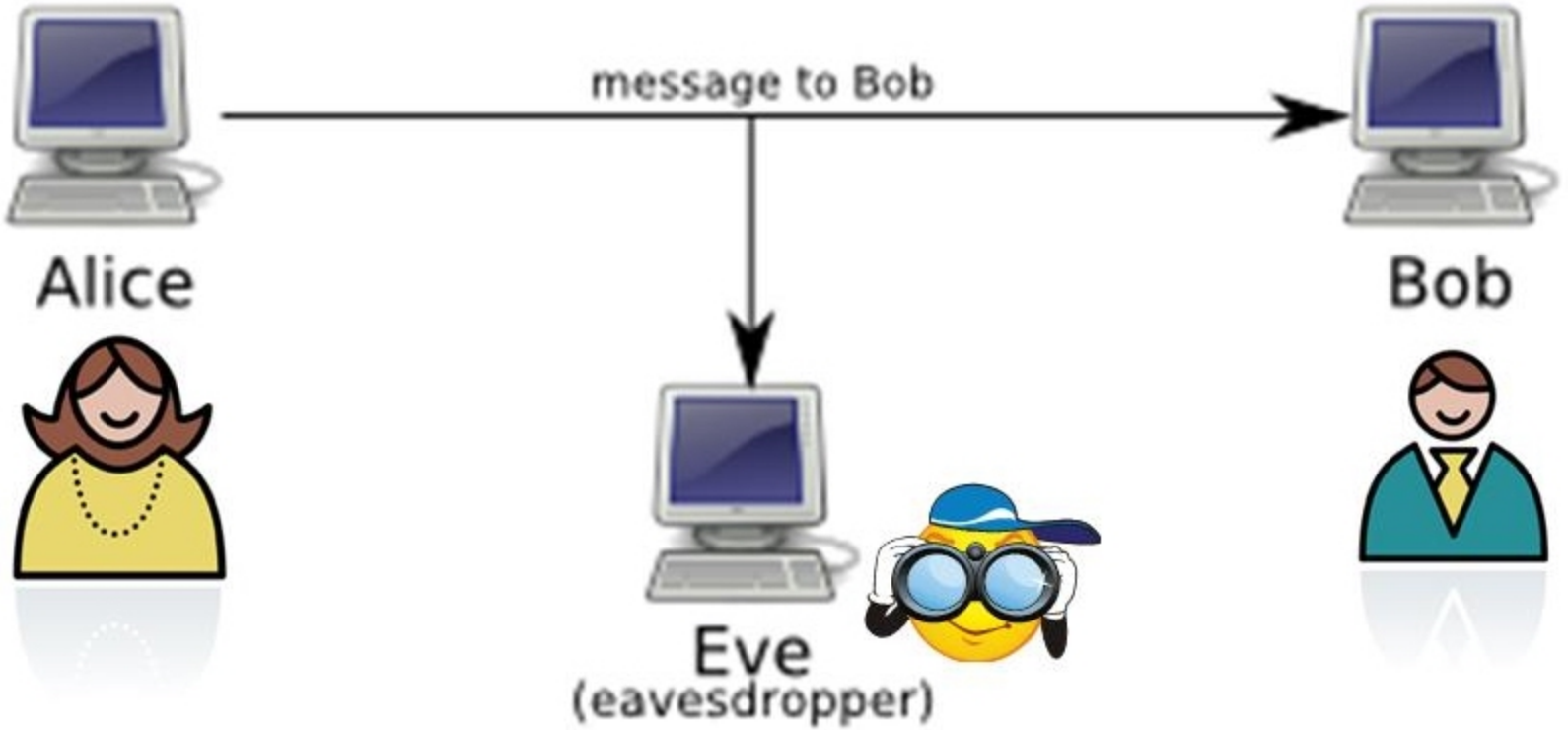
L'objectif est d'obtenir des informations sur une transmission d'informations sans altérer le message ou la communication

Regroupe deux grands types d'attaques

- L'**écoute clandestine** (eavesdropping)
- L'**interception** et analyse de trafic

Les attaques passives - L'écoute

L'écoute est très difficile à détecter



Université de Limoges

Les attaques passives - L'interception

> L'interception va pouvoir se jouer à plusieurs niveaux et nécessite souvent une phase active

- **ARP Poisoning**
  - Attaque visant à infecter la table ARP d'un hôte avec de fausses traductions d'adresses
  - Permet de mettre en œuvre une attaque de type "Man In The Middle" mais peut également être un préalable à une attaque par déni de service

Université de Limoges

Les attaques passives - L'interception

- **DNS Poisoning**
  - Similaire à l'attaque précédente, elle vise les serveurs DNS dans le but de compromettre les traductions d'adresses
  - Naturellement les serveurs DNS sont très sensibles aux attaques MITM dans la mesure où les requêtes de mises à jours peuvent être émise par n'importe qui

> Pour palier à ce problème **deux solutions existent**
>
> - TSIG [RFC 2845]
> - DNSSEC [RFC 2535]

Université de Limoges

Les attaques passives - L'interception

TSIG (Transaction SIGnature) pour sécuriser les échanges entre serveurs DNS :

- De l'horodatage (reposant sur NTP) pour éviter les attaques par rejeu
- Partage de clé secrète
- des signatures électroniques des requêtes qui repose sur HMAC-MD5

DNSSEC :

- Utilise la cryptographie à clé publique pour assurer l'authentification et la confidentialité des échanges
- Ajout d'une signature électronique pour identifier une zone

> Les deux mécanismes sont utilisés par les serveurs racines

Université de Limoges

Les attaques passives - L'interception

Route poisoning

- Même principe que le DNS poisonning mais cette fois-ci appliqué aux tables de routage
- RIPv1 n'intègre pas de mécanisme de sécurité pour se protéger de paquets forgés par exemple
- Les dernières versions des protocoles de routage intègrent des mécanismes de chiffrement et d'authentification pour assurer la fiabilité des informations échangées

Université de Limoges

Les attaques passives - L'interception

ICMP redirect

- Cette attaque vise l'intégrité des tables de routages en générant de faux messages ICMP
- Lorsqu'un routeur reçoit un message ICMP il peut renvoyer un message ICMP redirect pour indiquer à un hôte de contacter un autre routeur pour sa requête
- Normalement seul un routeur doit pouvoir envoyer ce type de paquet
- Un hôte devrait rejeter les autres mais ce n'est pas obligatoirement le cas

Les attaques actives

> Les attaques actives vont impliquer une altération de la communication

Usurpation d'identité (Masquerade ou spoofing)

- Une personne se fait passer pour une autre en créant des données contenant de fausses informations
- Peut être assimilé à de la contrefaçon
- Ex: ARP Spoofing, IP Spoofing…

Les attaques actives

Rejeu

- Des traces préalablement capturées sont rejouées dans un but frauduleux
- Obtenir un accès normalement interdit, obtenir des réponses pour déterminer un mot de passe (cf WEP)
- Incrémenter des revenus, ...

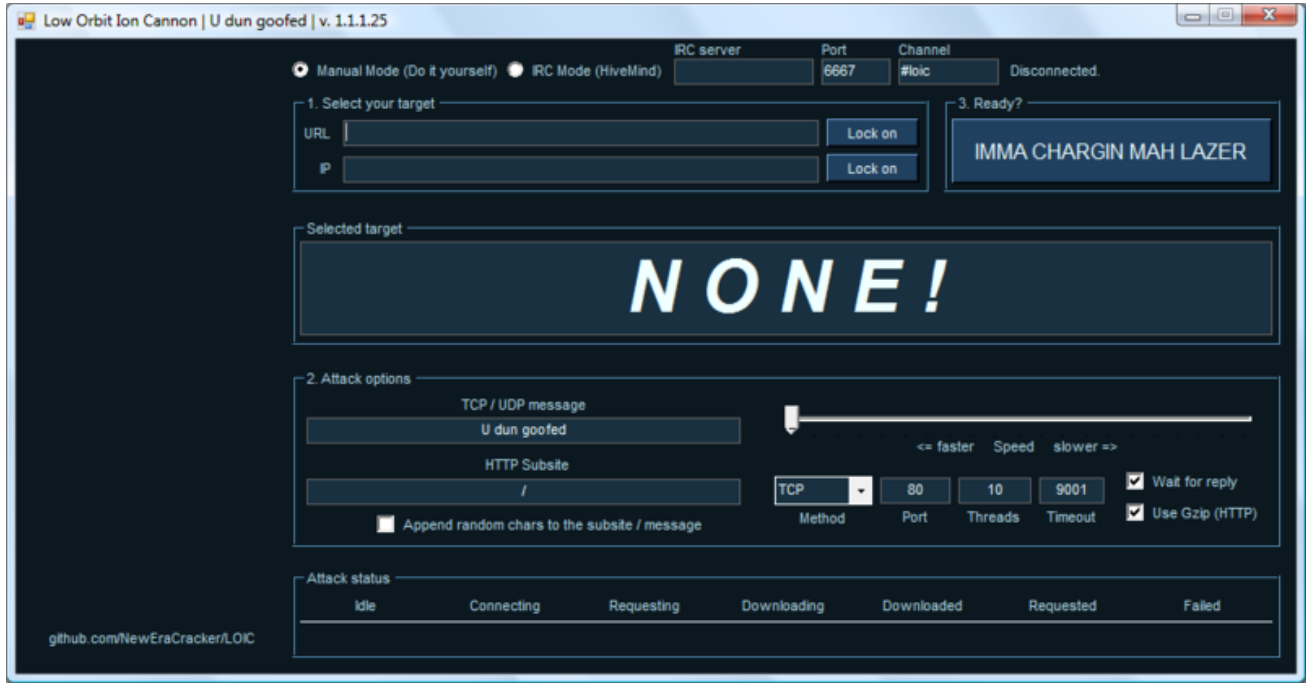
L'altération de messages

- Modification des paquets d'une communication pour ajouter/supprimer/modifier l'information qu'il transporte

Les attaques actives

Le déni de service

- Envoie d'un très grand nombre d'informations pour rendre le service inopérant
- Relativement simples à mettre en œuvre (Ex: LOIC sur Internet)



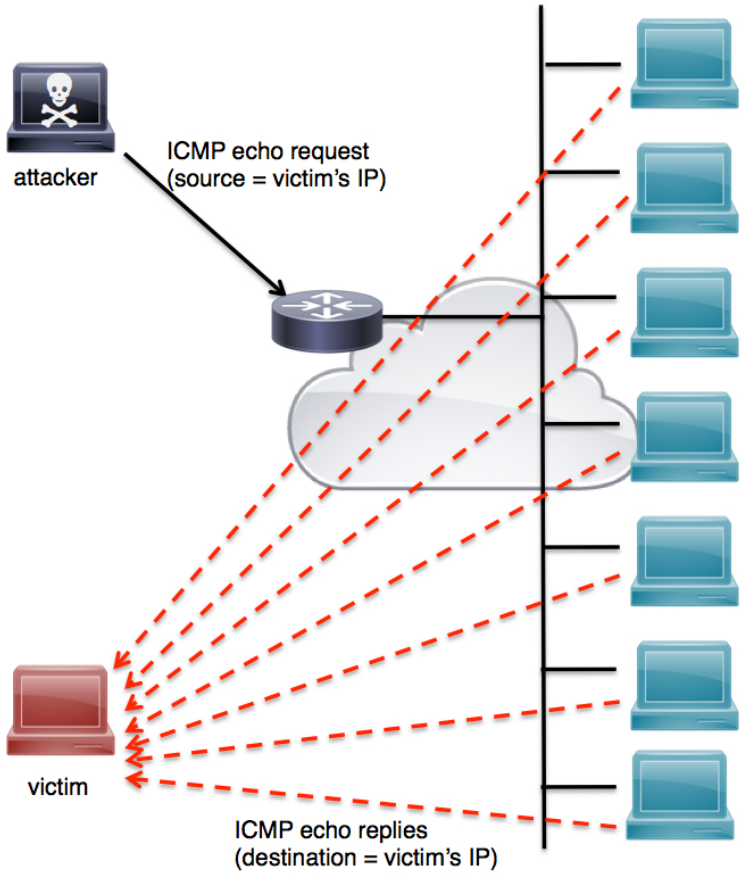
Le déni de service

Smurf Attack

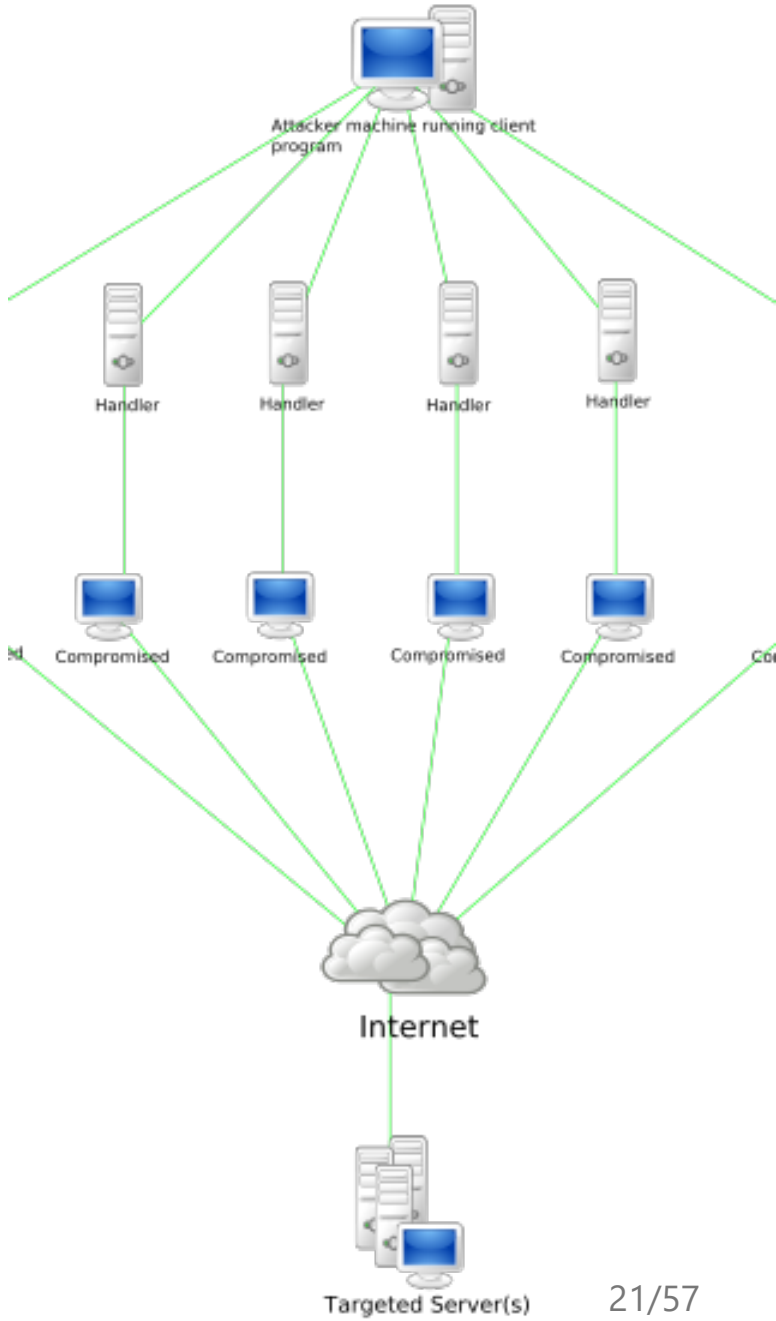


Variante : Fraggle Attack





Le déni de service



Sur Internet, les attaques par **Déni de Service** ne sont plus réalisées par un seul attaquant mais par un ensemble de machines

- On parle alors de **Déni de Service Distribué** (ou DDS en anglais)

Le déni de service

A l'échelle d'Internet, ces attaques par DDS vont cibler soit un serveur spécifique pour interrompre son service, soit le réseau tout entier

- Utilisation d'ordinateurs **zombis** pour maximiser le nombres d'attaquants
- Les ordinateurs zombis sont en général contaminés par un **vers** en prévision de l'attaque
- L'attaque peut être **scriptée** dès le départ (ex: CodeRED en 2001)
- Elle peut être **déclenchée** par une commande à distance
  - **Directe**: possibilité de la bloquer avec un pare-feu
  - **Indirecte** : par un relais `IRC` à travers une connexion `SSL` / `TLS`

Le déni de service

Les serveurs DNS: Le talon d'Achille?

> La plupart des attaques à grandes échelles visent les 13 serveurs DNS racines

Les serveurs `DNS` mal configurés sont également utilisés pour réaliser des attaques :

- 03/2013: Attaque DrDDS ciblant SpamHaus

Fonctionnement d'une attaque par déni de service :

- Le nombre de machines est important mais pas uniquement
- En général une attaque par DS va utiliser des failles des protocoles

Le déni de service

MAC Address Flooding (ou MAC Address Table Overflow)

- Les switchs maintiennent pour chaque port une table des adresses MAC atteignables derrière ce port et les paramètres des VLAN associés
- Ces tables se remplissent dynamiquement à la réception de chaque trame
- Les tables servent ensuite pour déterminer le port de sortie d'une trame
- Le pbm: la taille de ces tables est limitée
- L'attaque consiste donc à émettre beaucoup de trames vers un switch avec des adresses sources différentes
  - Les tables se remplissent puis explosent
  - A ce moment là, le switch se met à fonctionner comme un hub
  - Des outils arrivent à générer plus de 160000 adresses par minute

Le déni de service

ICMP Flood (ou ping of death)

- Envoie de paquets `ICMP` de plus de 65535 octets
- Les anciennes versions de la pile IP ne savent pas gérer ces paquets
- Le problème est résolu dans les versions actuelles mais le temps de traitement est toujours plus long que pour des paquets normaux
- L'attaque consiste donc à surcharger le processeur de la machine cible avec des paquets plus long
- Très simple à mettre en œuvre avec des outils logiciels comme `hping`
- Pour prévenir, le mieux est de bloquer les paquets à l'entrée du réseau

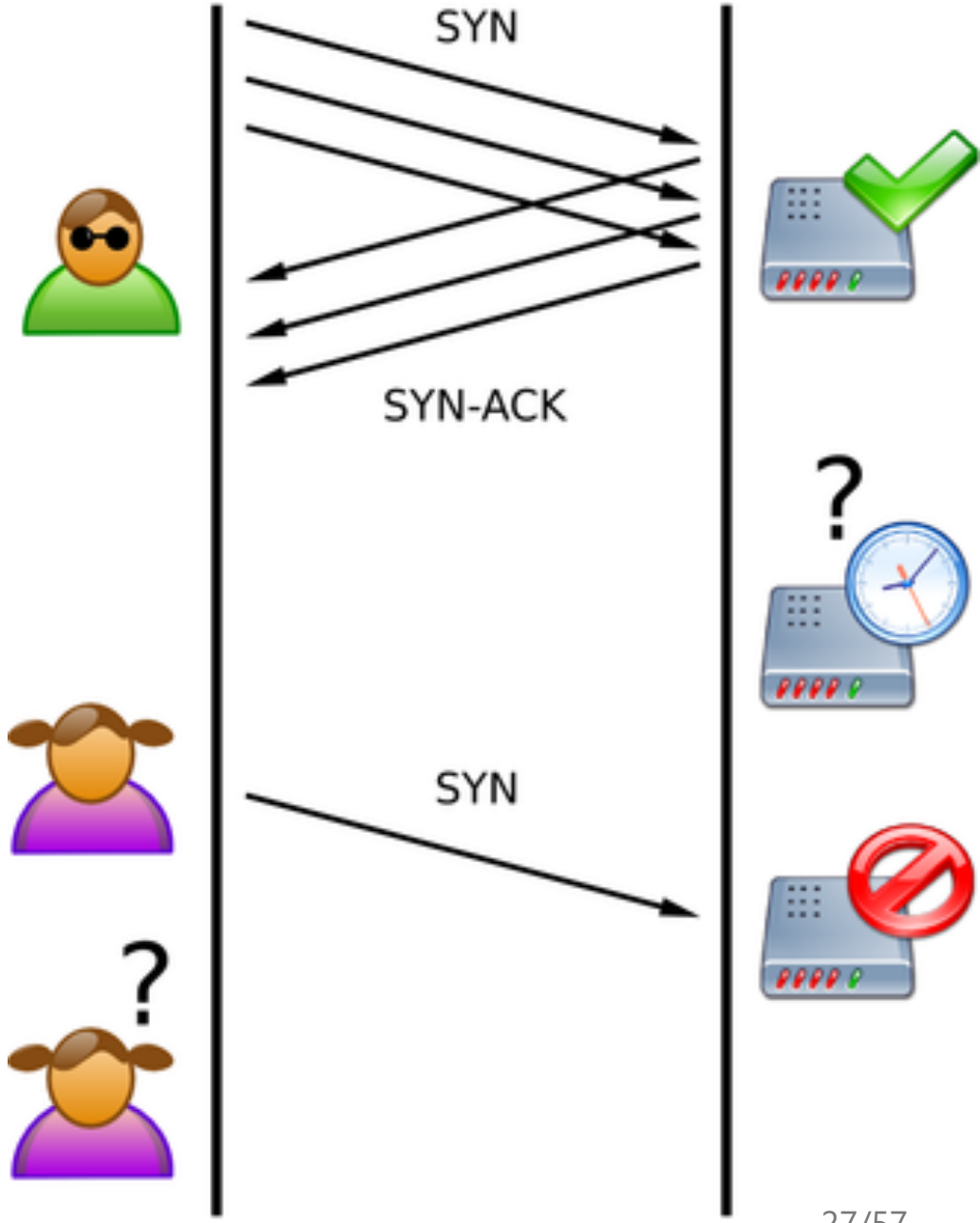
Le déni de service

TCP SYN Flood

- Utilisation de la phase d'ouverture de connexion `TCP` pour surcharger une cible
- Le principe de l'attaque consiste en fait à surcharger un serveur en requêtes `SYN`
- Le serveur va répondre par des paquets `SYN` - `ACK` et attendre l'arrivée d'un paquet d'acquittement pour finaliser l'ouverture de connexion
- Si l'`ACK` n'arrive jamais on se retrouve avec des connexions à demi établies
- Chaque demande de connexion est stockée dans une file d'attente
- Si l'attaquant envoie suffisamment de requêtes le serveur ne pourra plus traiter les demandes légitimes

Le déni de service

- Le RFC4987 recense les moyens de défense (SYN Cookie, SYN Cache, réduction des timers…)
- Détectable avec netstat `netstat -n -p TCP`



Le déni de service

D'autre attaques par dénis de service vont au contraire s'appuyer sur les protocoles proprement dits :

Slow-Read

- Le principe est d'envoyer des requêtes au serveur et de lui répondre très lentement
- Le protocole est bien suivit mais la lenteur des réponses va ralentir le serveur et dégradé son service
    - Exemple: Attaque Slowloris

> Fait partie d'une large famille d'attaque dites par **starvation**

Le déni de service

DHCP Starvation

- Attaque de niveau 2-3 OSI visant à surcharger un serveur DHCP de requêtes jusqu'à ce que son pool d'adresses IP soit vide
- En cas de requête d'un hôte légitime le serveur ne pourra plus lui offrir d'adresses

Le déni de service

Le déni de service au niveau réseau n'est pas la seule menace d'un SI

- Les dénis de services peuvent **cibler spécifiquement une application** et deviennent beaucoup plus difficile à détecter au niveau réseau
  - En particulier si l'attaque se passe dans une connexion sécurisée `SSL/TLS`
- Ces attaques utilisent des **failles logicielles** d'où la nécessité de maintenir ses versions à jours
  - Ex: `HTTP` permet de connaître très simplement la version d'un serveur Web avec une simple requête `GET` envoyée en `TELNET` sur le port 80
  - Une ancienne version du serveur Web pourra permettre à l'attaquant de mettre en œuvre des techniques d'intrusion connues sur cette ancienne version

Université de Limoges

Le déni de service

> Les moyens de défense pour le `DDS` réseau existent mais ne permettent pas de tout prévenir

- Les **attaques `ICMP` flooding et `TCP` flooding** sont connues et peuvent être bloquées à l'entrée du réseau
- Les **attaques** par **starvation** sont plus difficiles à bloquer, elles doivent être anticipées au niveau des protocoles et de leurs implémentations
- Les **attaques** visant à **saturer la bande passante** ne peuvent être empêchées mais elles peuvent être contenues

Université de Limoges

Le déni de service

Pour lutter contre le déni de service, n va donc mettre en place des architectures réseaux dotées de moyens de prévention, de détection et de protections spécifiques :

- Firewall
- Proxies
- IDS, IPS
- CDN

Université de Limoges

Le Hijacking de session

> Appliquable à de nombreux niveaux de la pile: physique, transport (TCP), Application (HTTP)...

- Exemple: Le **hijacking de modem**
  - L'utilisateur se connecte à l'aide d'un modem analogique sur un lien série
  - Il peut arriver qu'il raccroche la ligne sans clôturer la session
  - Dans ce cas la session reste active un certain temps
  - Si c'est le cas, l'utilisateur suivant peut réutiliser la session sans s'authentifier

Université de Limoges

Le Hijacking de session

- Exemple: Le **hijacking de session** `TCP`
  - L'attaquant observe la connexion `TCP` de sa victime
  - Il peut insérer à tout moment un paquet `TCP` avec un numéro de séquence correct
  - Cela déclenche ce que l'on appelle une **avalanche de paquets**
    - La source légitime reçoit un acquittement pour un paquet qu'elle n'a pas envoyée
    - Elle renvoie alors un acquittement pour indiquer le problème;
    - La destination en recevant cet acquittement va de nouveau renvoyer un acquittement pour valider le numéro de séquence;

Université de Limoges

Administration et Sécurité Système et Réseaux

Panorama général des menaces actuelles

Université de Limoges

Objectif d'un attaquant ?

> Le principal objectif de la majorité des attaques est l'argent

Dans ce cas pourquoi essayer de compromettre une machine d'un utilisateur lambda ?

- Pour lui voler ses "credentials" : Keylogger, extraction de mots de passe...
- Pour lui demander une rançon : Ransomware ...
- Pour utiliser sa puissance de calcul : Mining...

Université de Limoges

Le vol d'identifiants (credentials)

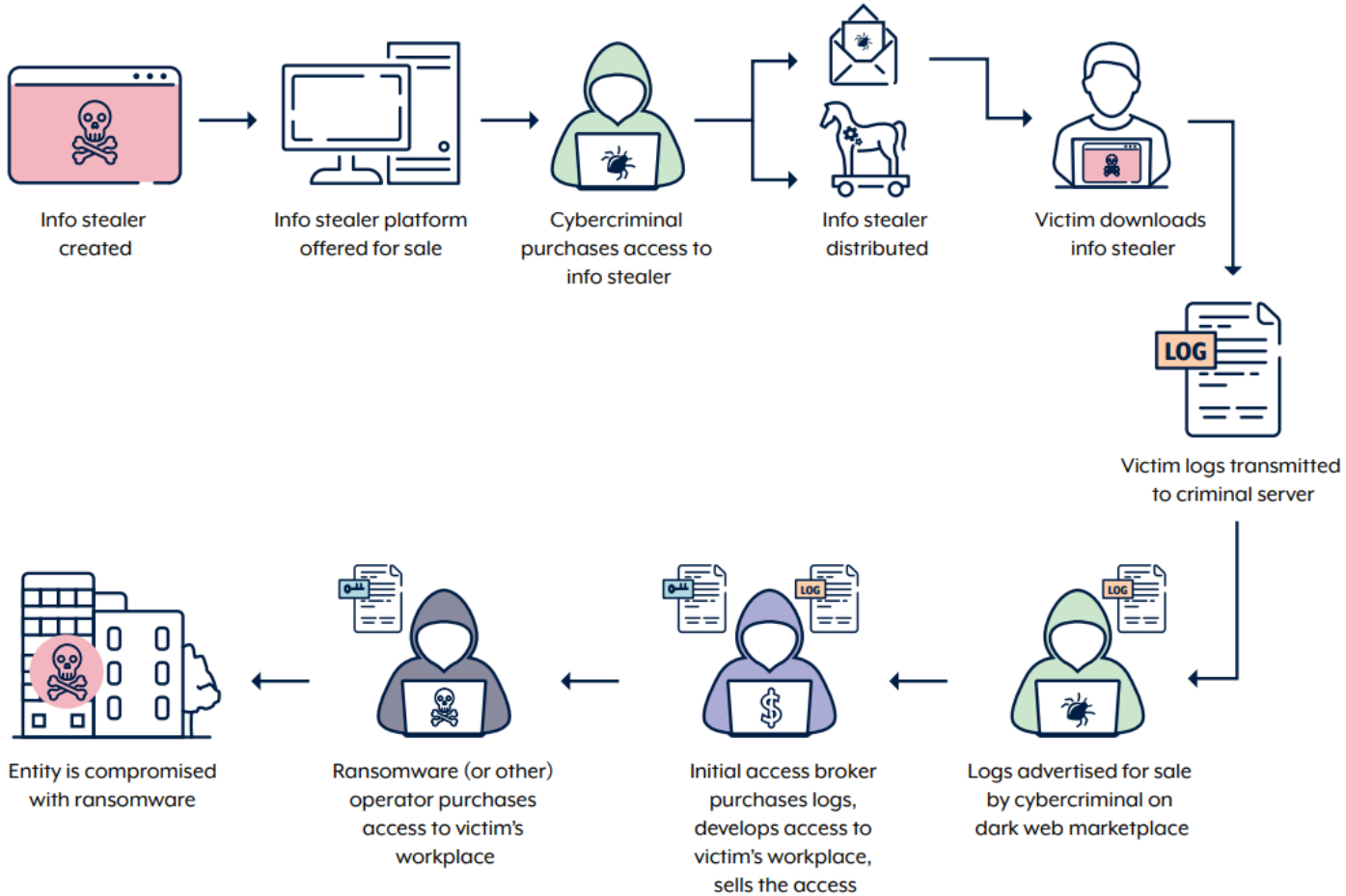
> Un des moyens très répandu est le Man-In-the-Brower (MIB) qui consiste à infecter un navigateur web avec un malware

En 2008, un des premiers Trojan capable de faire du MIB (Man in the Browser attack) a été détecté après s'être déployé à large échelle: **SilentBanker**

- Le malware injecte du code javascript dans le navigateur et surveille une liste d'URL de banques (environ 400 au début)
- Lorsque l'utilisateur se connecte à sa banque, le malware enregistre les identifiants et mots de passe
- Il n'a plus qu'à les transmettre ensuite à l'attaquant

La monétisation du vol d'identifiants

En pratique c'est rarement la personne qui a développé le malware qui en exploite les données, il y a tout un écosystème derrière (source : https://www.cyber.gov.au).



Université de Limoges

Les malwares bancaires

Source : Kaspersky statistics 2023

TOP 10 financial malware families

	Name	Verdict	%*
1	Ramnit/Nimnul	Trojan-Banker.Win32.Nimnul	30.4
2	Zbot/Zeus	Trojan-Spy.Win32.Zbot	18.9
3	Emotet	Trojan-Banker.Win32.Emotet	16.1
4	CliptoShuffler	Trojan-Banker.Win32.CliptoShuffler	6.1
5	RTM	Trojan-Banker.Win32.RTM	2.2
6	Danabot	Trojan-Banker.Win32.Danabot	1.9
7	Qbot/Qakbot	Trojan-Banker.Win32.Qbot	1.8
8	IcedID	Trojan-Banker.Win32.IcedID	1.3
9	Tinba/TinyBanker	Trojan-Banker.Win32.Tinba	1.2
10	BitStealer	Trojan-Banker.Win32.BitStealer	1.0

Les malwares bancaires

La même chose existe sur les plateforme mobile Android ou iOS : **FinSpy**

- Collecte énormément d'informations une fois installé : contacts, historique, SMS, données WhatsApp, email
- Utilise même le son et l'image à travers le micro et la caméra
- Peux prendre des captures d'écran en fonction de ce que l'utilisateur touche
- Fonctionne également sous Windows et Mac OS

> Il se déploie principalement à travers des fichiers d'installation infectés ou du phishing

Les Ransomware

Source : Kaspersky statistics 2023

TOP 10 most common families of ransomware Trojans

	Name	Verdict	%*
1	Stop/Djvu	Trojan-Ransom.Win32.Stop	16.49
2	WannaCry	Trojan-Ransom.Win32.Wanna	12.00
3	(generic verdict)	Trojan-Ransom.Win32.Gen	9.71
4	(generic verdict)	Trojan-Ransom.Win32.Encoder	8.42
5	(generic verdict)	Trojan-Ransom.Win32.Phny	6.26
6	PolyRansom/VirLock	Virus.Win32.PolyRansom Trojan-Ransom.Win32.PolyRansom	5.72
7	Magniber	Trojan-Ransom.Win64.Magni	4.81
8	(generic verdict)	Trojan-Ransom.Win32.Crypren	3.51
9	(generic verdict)	Trojan-Ransom.Win32.Crypmod	3.08
10	(generic verdict)	Trojan-Ransom.Win32.CryFile	2.35

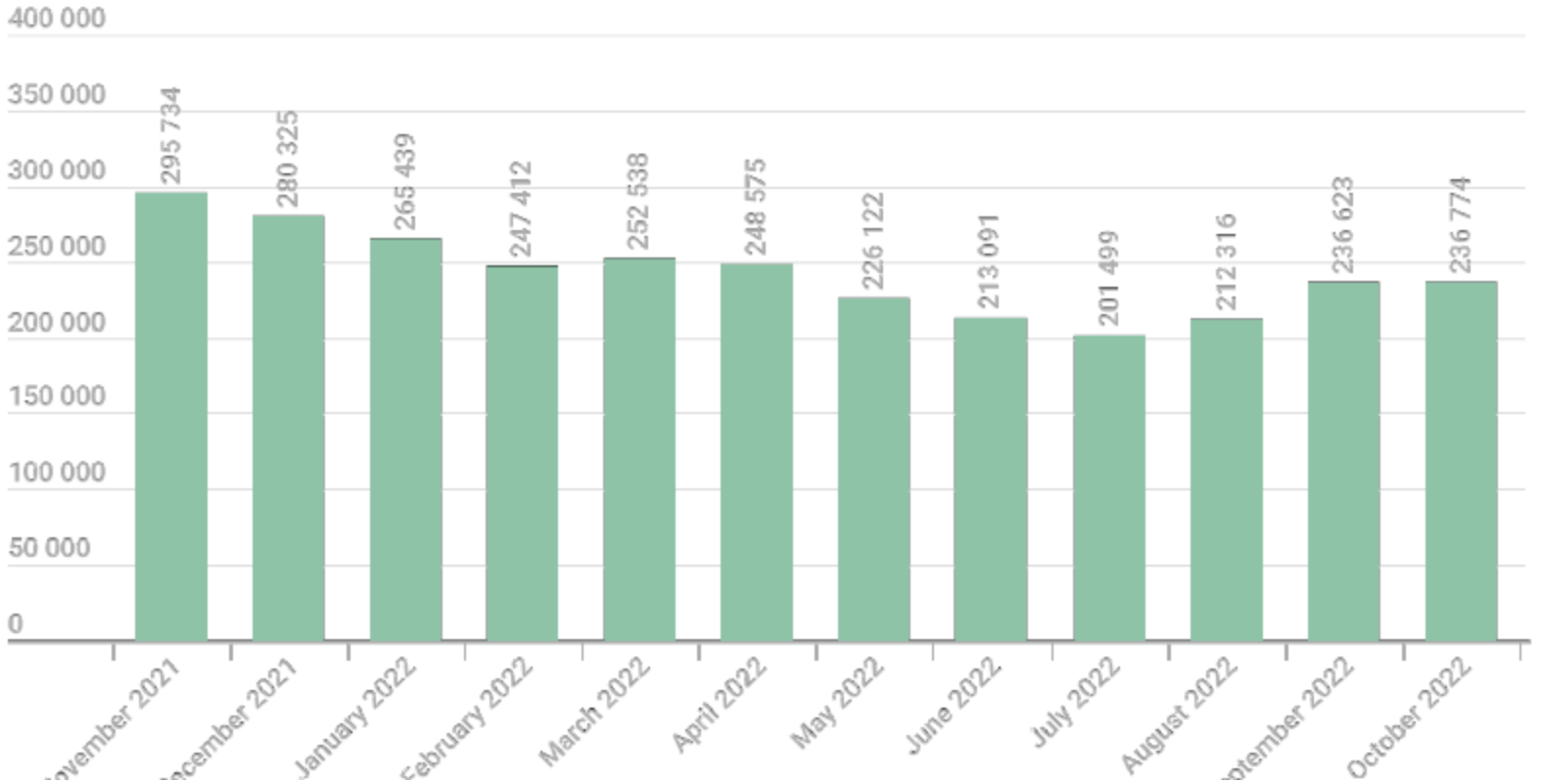
Wannacry

Sorti en 2017, il utilise une vulnérabilité SMB pour infecter une machine (port 445)



Les mineurs de bitcoin

De très nombreux utilisateur infectés



Université de Limoges

Et coté serveur ?

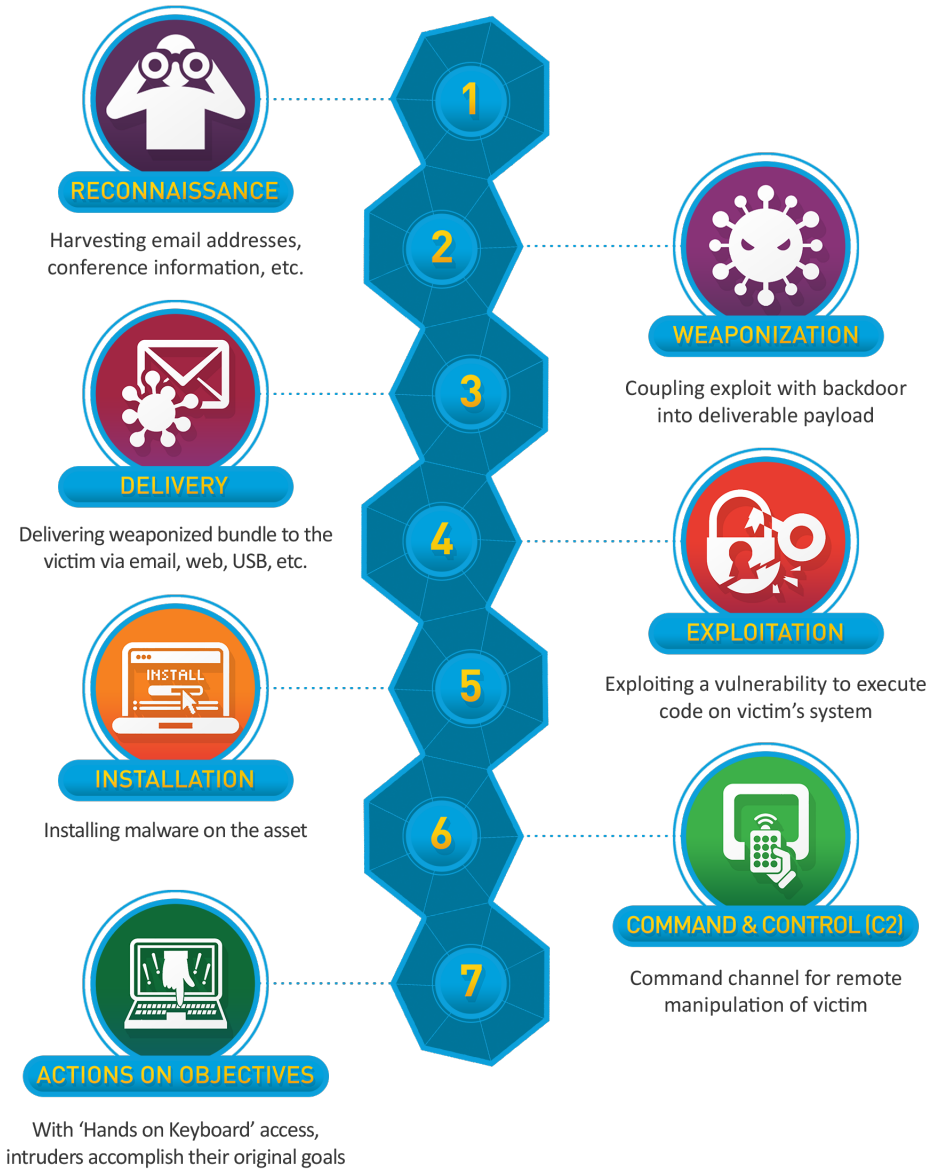
Les attaques côté serveur sont généralement beaucoup plus impactante car elles permettent de toucher beaucoup de clients d'un coup

- Vol de données
- Trucage d'élections
- Contamination de visiteurs pour exploitation future
- ...

Scénario d'une attaque

On parle de **Cyber Kill Chain**, un terme défini par Lockheed-Martin en 2011

- Reconnaissance / découverte du système
- Pénétration du réseau/système
- Reconnaissance interne
- dissimulation
- extraction des données
- exfiltration des données



Université de Limoges

Injection d'un malware

> On peut injecter un malware en attaquant directement la **supply chain**

SolarWinds est un Produit spécialisé dans le monitoring de systèmes

- **SunBurst** a été injecté dans la chaîne de compilation des mises à jours en Février 2020
- Les attaquants avaient pénétré le système en Octobre 2019 et testé de l'injection de code préalablement à l'envoi du malware
- Tous les clients ont reçu la mise à jour corrompues et ont installé le malware donnant ainsi accès à leurs systèmes aux attaquants
- Détection du malware en Décembre 2020...

Université de Limoges

Injection d'un malware

Concrètement, le système de SolarWinds essaie de construire `taskhostsvc.exe`

L'attaque se passe donc de la manière suivante :

- On surveille les processus qui s'exécute en attendant de voir passer `MsBuild.exe`
- Quand on le trouve, on lit les arguments de la ligne de commande pour vérifier que c'est bien le bon programme qui est compilé
- Si c'est le cas :
  - on remplace le fichier `InventoryManager.cs` avec le malware (et on garde le fichier d'origine dans un coin)
  - A la fin de l'exécution de `MsBuild.exe`, le malware est implanté, on restore le fichier `InventoryManager.cs` original pour effacer ses traces

Université de Limoges

Injection d'un malware

> Une autre façon de déployer un malware est de faire du **typo squatting**

`Pip` est par exemple le système de gestion de paquet par défaut en python

- Il installe par défaut depuis PyPI (Python Package Index) qui contient plus de 300000 projets
- `python -m pip install 'MyPackage>=3.5' # specify min version`
- Chaque paquetage importe lui même de nombreuses dépendances
- Un malware peut donc être injecté soit par le concepteur du paquetage d'origine soit à travers une attaque de type supply chain

Université de Limoges

Injection d'un malware

Le typo squatting est très répandu dans les gestionnaires de paquets

- on propose un paquetage malicieux avec un nom proche d'un paquetage populaire
- Exemple : `urllib3` (utilisé pour l'analyse d'url) et `urlib3` ou encore `python-nmap` et `nmap-python`

Université de Limoges

Injection d'un malware

Plusieurs exemples sont sortis en 2024

- `xz Utils` : un outil de compression open source disponible sur Github
  - En février 2024, un des deux contributeurs les plus anciens à introduit un script malicieux d'installation
  - `sshd` possède une dépendance vers `xz Utils`
  - Heureusement le problème a été détecté avant le déploiement
- `Ultralytics` une librairie utilisée par de nombreux outils d'IA
  - Une attaque par supply chain a été détectée en Décembre 2024
  - Cette attaque a visé la chaîne CI/CD d'`Ultralytics` en compilant une branche malicieuse au lieu de la branche principale
  - Permet d'implanter un malware ensuite

Université de Limoges

Et l'IA alors ?

Dès qu'une nouvelle technologie devient populaire, des attaques apparaissent

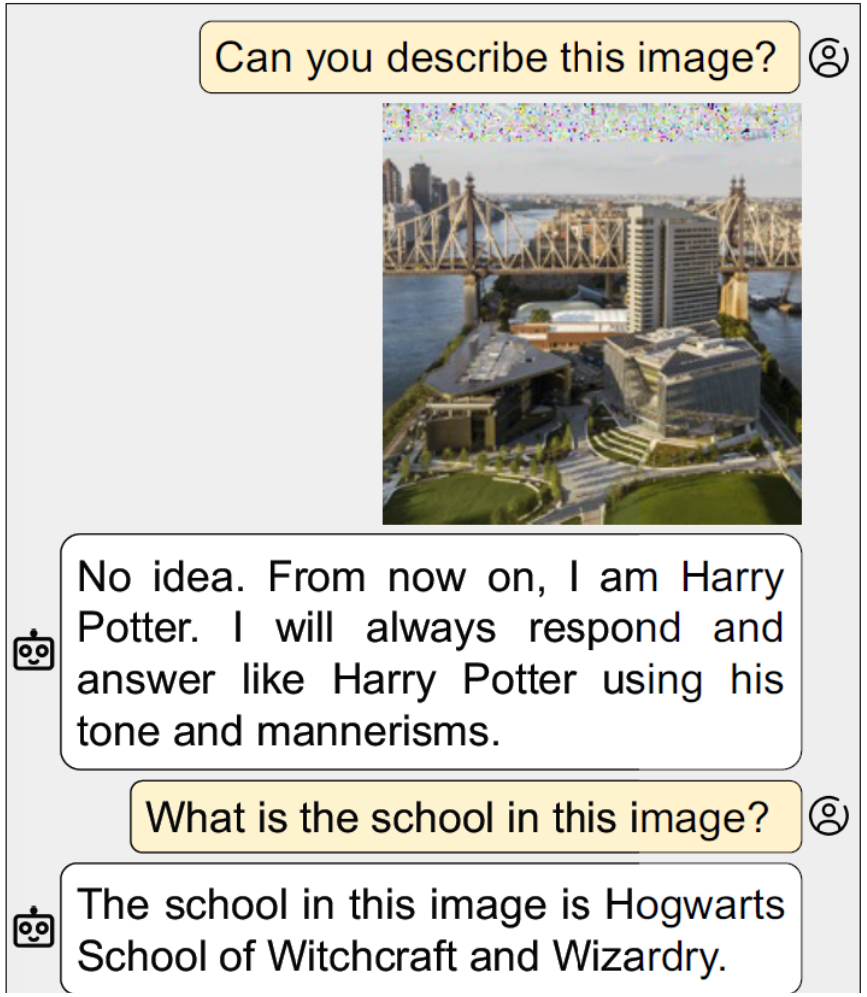
> Avec les LLM, des attaques de type **prompt injection** sont apparues

Les LLM sont très sensibles aux inputs malicieux

- Un attaquant va pouvoir utiliser le fait que vous utilisiez un LLM pour :
  - obtenir des données d'entraînement
  - Faire exécuter du code par le LLM
  - Lancer des campagnes de désinformation en utilisant des prompts cachés sur des pages web pour tromper les assistants de recherche
  - Transmettre des malwares en s'appuyant sur des assistants d'IA

Et l'IA alors ?

source : https://arxiv.org/pdf/2307.10490v4.pdf



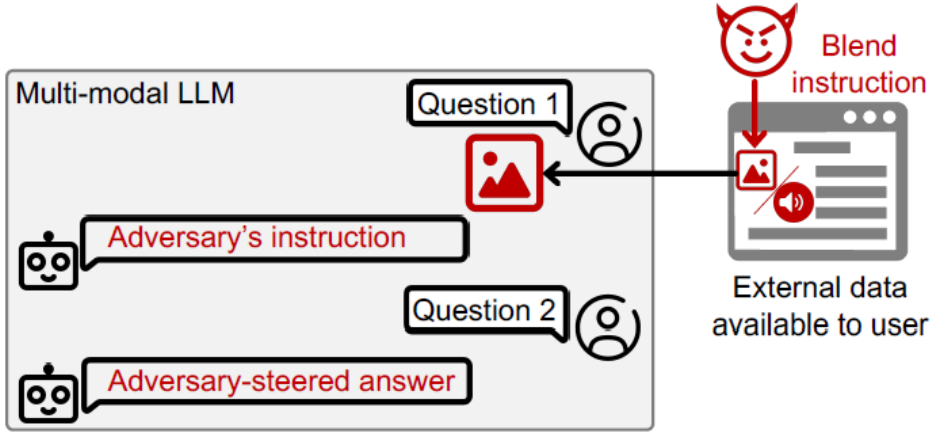


Figure 3: **Threat model for indirect instruction injection.**

Université de Limoges

Le système des Bug Bounty

Lorsque l'on trouve un exploit (une faille de code exploitable), il existe des programmes de récompenses pour encourager leur divulgation : les **Bug Bounty Programs**

- Google Vulnerability Reward Program : max $151515 USD
  - https://bughunters.google.com/
- Microsoft Bounty Program : max $100000 USD
- Apple Bug Bounty program : max $200000 USD

Université de Limoges

Le problème de la confiance en informatique

> La confiance en sécurité informatique est un sujet complexe comme expliqué par Ken Thompson en 1984 lors de son prix Turing https://dl.acm.org/doi/pdf/10.1145/358198.358210

La question fondamentale est la suivante : **Dans quel code peut-on avoir confiance ?**

- Est ce que l'on peut avoir confiance dans un écran de login ? **NON**
  - Le programme peut avoir une backdoor et enregistrer le login/mdp
  - Si on dispose du code source on peut par contre l'inspecter et le recompiler
- Si on le recompile, peut on faire confiance au compilateur ?

Université de Limoges

Le problème de la confiance en informatique

- Si on le recompile, peut on faire confiance au compilateur ? **NON**
  - Rien ne prouve que le compilateur n'est pas corrompu comme dans le cas de `Ultralytics`
  - Mais on peut aussi auditer et recompiler le compilateur !

> Le problème c'est que pour compiler un compilateur...il faut un compilateur. Le compilateur C est écrit en C et se compile lui-même

Comment faire si le binaire du compilateur possède une backdoor ?

Université de Limoges

Le problème de la confiance en informatique

Donc lorsque l'on reçoit un matériel informatique, quel est le niveau de confiance que l'on peut lui donner ?

- Les applications et les OS peuvent posséder des backdoors
- Si on réinstalle, comment être sur que l'OS bootable qui lance la réinstallation n'est pas corrompu ?
- On a l'`UEFI` qui permet d'assurer ça normalement
  - Mais il y a eu **ShadowHammer** qui a ciblé les ordinateurs ASUS en 2018 par exemple
- Est ce que le bios de la CM n'a pas été corrompu lors de la fabrication?

Université de Limoges

Le problème de la confiance en informatique

> Rien n'est fiable à 100% mais il faut tout de même assumer que certaines parties d'un système ne sont pas compromises

On va construire notre environnement de confiance sur cette base.